

Materia

Seguridad en el Desarrollo de Aplicaciones

Nombre

Ricardo Porras Reyes

Matricula

2024171008

Grupo

IDSG17

Profesor

Gerardo Ramírez Villarreal

Captura de búsqueda legítima.

< > ↺ 🌐 localhost:5182/Search/Index

VulnerableApp Home Privacy

Buscar Usuarios

admin

Buscar

Username	Email	Balance
admin	admin@test.com	\$1000.00

VulnerableApp Home Privacy

Buscar Usuarios

Busca usuario...

Buscar

Username	Email	Balance
user1	user@test.com	\$500.00

Captura de búsqueda manipulada.

VulnerableApp Home Privacy

Buscar Usuarios

' OR '1'='1

Buscar

Username	Email	Balance
admin	admin@test.com	\$1000.00
user1	user@test.com	\$500.00
user2	user2@test.com	\$750.00

Captura del código vulnerable.

```
string query =  
    "SELECT * FROM Users WHERE Username LIKE '%" +  
    search +  
    "%'";  
  
var users = db.Users
```

La vulnerabilidad identificada corresponde a CWE-89 (SQL Injection) y a la categoría Injection de OWASP.

La causa es la construcción dinámica de la consulta SQL mediante concatenación de cadenas utilizando datos proporcionados por el usuario.

Código vulnerable:

```
string query = "SELECT * FROM Users WHERE Username LIKE '%" + search + "%'";
```

Al no utilizar parámetros, una entrada manipulada puede modificar la estructura de la consulta SQL original y alterar su comportamiento esperado.

Impacto:

- Exposición de información.
- Acceso no autorizado a registros.
- Posibles modificaciones o eliminación de datos en escenarios reales.

Ubicación:

SearchController.cs